



2016 中国互联网安全大会
China Internet Security Conference

协同联动 共建安全⁺命运共同体

Dynamic DNS Abuse

Chris Baker

Senior Principal Data
Analyst

```
; <<>> DiG 9.8.3-P1 <<>> datumrich.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 1337H@X0R
;; flags: qr aa ra; QUERY: 1, ANSWER: 1, AUTHORITY: 1, ADDITIONAL: 0

;; QUESTION SECTION:
chris.baker.      3600      IN  NS       ns1.dyn.com.
chris.baker.      138547    IN  MX       cbaker@dyn.combaker@dyn.com
chris.baker.      3600      IN  TWEET    @datumrich

;; Query time: 111 msec
;; SERVER: 127.0.0.1#53(127.0.0.1)
;; WHEN: Wed Aug 16 12:00:00 2016
;; MSG SIZE rcvd: 99
```



中国互联网安全大会



360互联网安全中心

Contents

Overview

1. Dynamic DNS Service
 - Criminal Cost Model
2. Data Available for Analysis
3. Interaction Patterns
4. Adapting Methodology
 - Jscript Infection
 - DNS Beaconing

Why Dynamic DNS?

Frank Denis @jedisct1:

“The price of an IP Address (V4 of course) is greater than the price of a domain name and the price of a domain is greater than the price of a subdomain.”

The business of Dynamic DNS is providing sub domains as a service

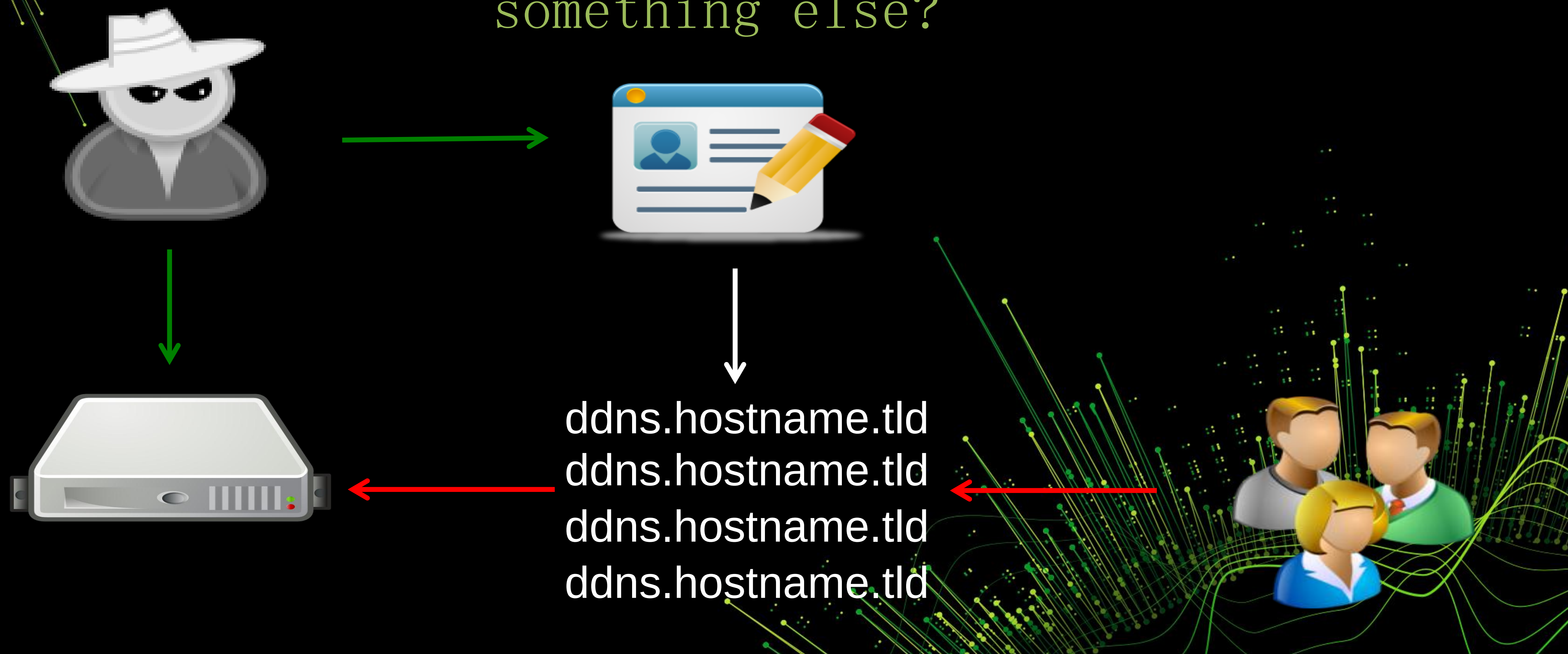
Investment Model



A criminal expends an account or a credit card when they create an account on our platform



The operating cost needs to be dwarfed by the profitability their activity otherwise wouldn't they do something else?





Apple Scam Phishing Website

Stop of spending money buying fullz from others sellers. It's time of get your own stuff! It is coded Apple website, very easy to get fullz!

Sold by AGENT3500ZERO - 12 sold since Jul 2, 2015
49 items available for auto-dispatch

Level 2

Features		Features	
Product class	Digital goods	Origin country	Worldwide
Quantity left	Unlimited	Ships to	Worldwide
Ends in	Never	Payment	Escrow

Download - 1 days - USD +0.00 / item

Purchase price: USD 0.90

Qty:

1

Buy Now

Queue

0.0037 BTC

Description

Bids

Feedback

Refund Policy

Product Description

Stop of spending money buying fullz from others sellers. It's time of get your own stuff! It is coded Apple website, very easy to get fullz!

apple scam

apple scam website

phising apple

apple

money

fullz

cheap

Overview / Summary

Creates: fj7e.is-an-actor.com



Phished person requests
fj7e.is-an-actor.com



They are redirect to:

<http://themanicnomad.com/wordpress/wp-content/plugins/rthytrgh/index.htm>

Example Page



中国互联网安全大会



360互联网安全中心

109.228.48.89/unlockid/restoreappleid/Login.php

Mac iPad iPhone Watch TV Music Support

Apple ID

Sign In Create Your Apple ID FAQ

Apple ID

Manage your Apple account

Apple ID

Password

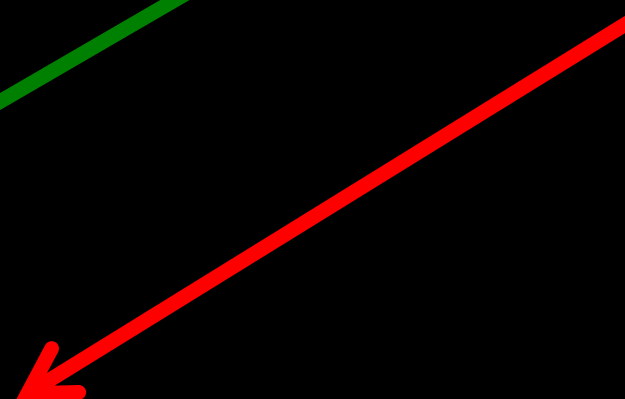
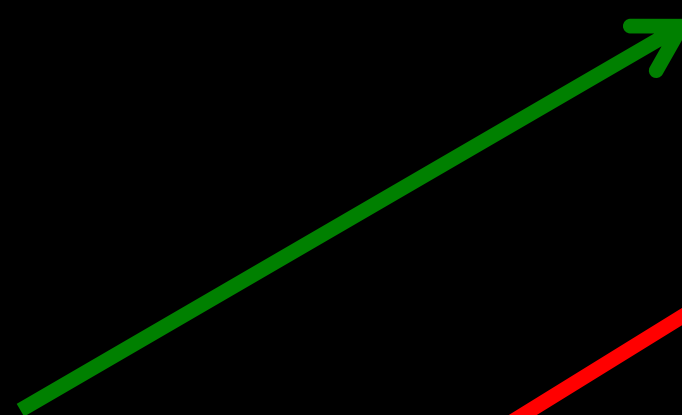
☐ Remember me

[Forgot Apple ID or password?](#)

Mile High Technical Summary



Modifies: fj7e.is-an-actor.com



Change fj7e.is-an-actor.com to sinkhole
Sinkhole -> <http://<Sinkhole-IP>/campaigntag-html.htm>

Total Possible Audience
(everyone in the spam list)

Audience Solicited

Message reached inbox

Message Opened

Link Clicked

Credentials Submitted

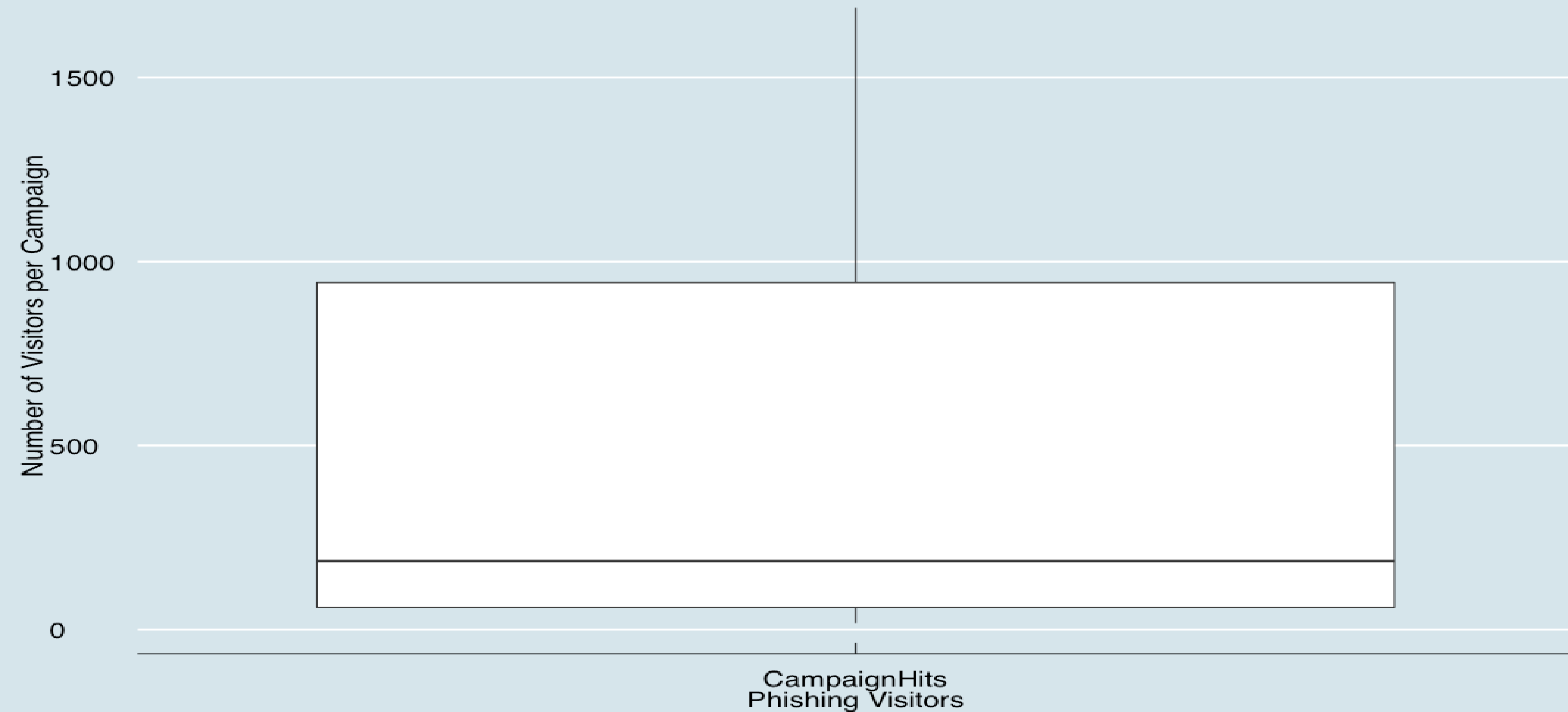
We have some sample data related to Apple phishing that are interesting

Sample Set of 45 Campaigns

Summary stats: Users who clicked the link / visited the redirection landing page

- Min: 18
- Median: 187
- Mean: 467
- Max 1689

Number of Visitors to Phishing Site





中国互联网安全大会



360互联网安全中心



3 x AppleID Account Logins

AppleID accounts mostly from the UK, some from other countries. Checked to be live before sending to you. Includes the login email address/password, account holder name, address, telephone numbers (daytime/evening/mobile - depending on what is set in the user account), IP address of account holder, associated device names and serial numbers. All listings available for these accounts: \$12 ...

Sold by **fullz** - 40 sold since Apr 9, 2015

Vendor Level 4

Trust Level 4

	Features		Features
Product class	Digital goods	Origin country	United Kingdom
Quantity left	64 items	Ships to	Worldwide
Ends in	Never	Payment	Escrow

RANDOM COUNTRY - 1 days - USD +0.00 / item

Purchase price: USD 12.00

Qty:

Buy Now

0.0308 BTC

Description

Bids

Feedback

Refund Policy

Product Description

AppleID accounts mostly from the UK, some from other countries.

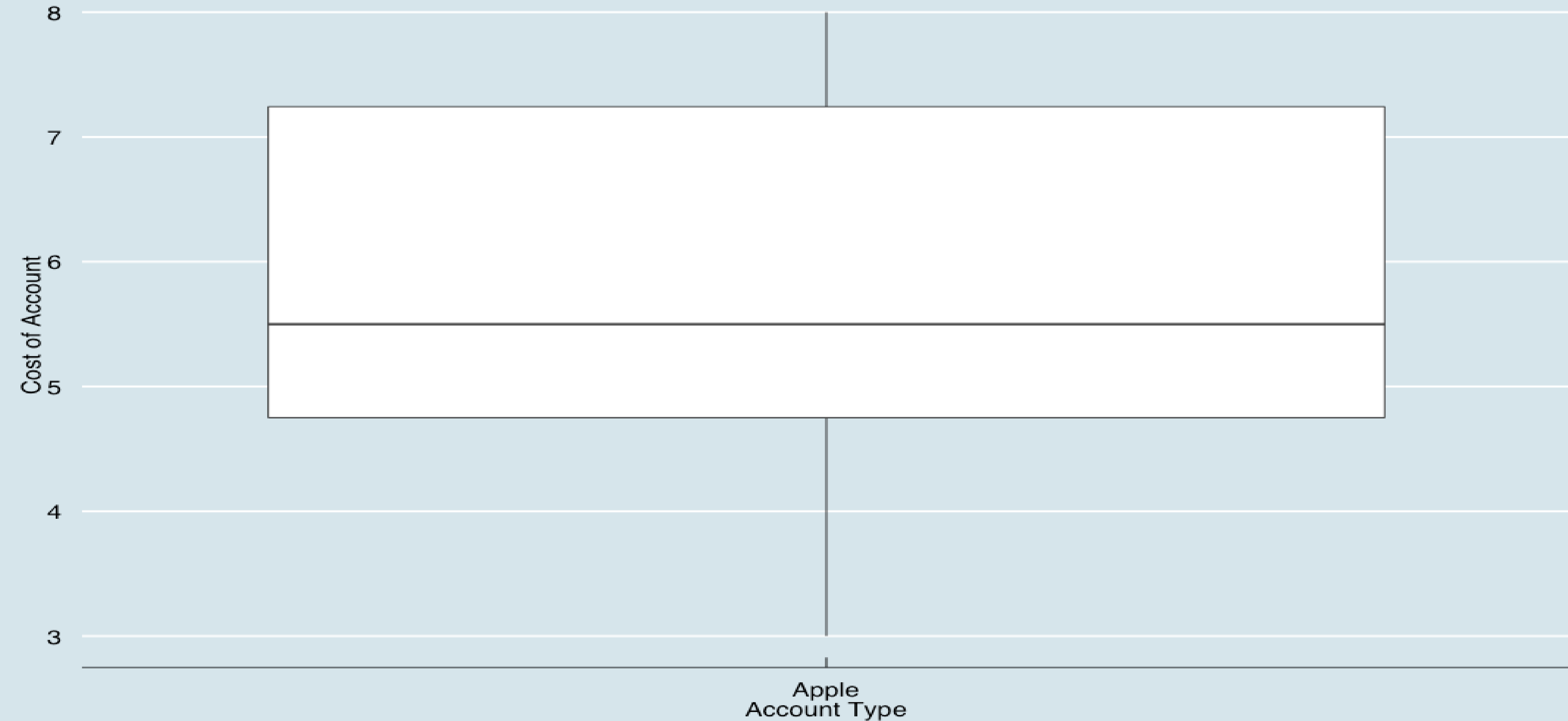
Checked to be live before sending to you. Includes the login email address/password, account holder name, address, telephone numbers (daytime/evening/mobile - depending on what is set in the user account), IP address of account holder, associated device names and serial numbers.

All listings available for these accounts:

\$12 (\$4/each) — 3 x AppleID Accounts — <http://pwoah7foa6au2pul.onion/listing.php?id=4784>

\$150 (\$3/each) — 50 x AppleID Accounts — <http://pwoah7foa6au2pul.onion/listing.php?id=4798>

Apple User Account: Advertised Price



	90%	70%	50%	30%
Min:	\$88.00	\$71.50	\$49.50	\$27.50
Median:	\$924.00	\$720.50	\$517.00	\$308.00
Mean:	\$2,310.00	\$1,798.50	\$1,287.00	\$770.00
Max	\$8,360.00	\$6,501.00	\$4,647.50	\$2,788.50

If we take the median price of \$5.50 per account we can estimate the profitability of various rates of credential submission and resale

Username
Date time
IP Address
User Agent String



Datetime
Hostname
IP Address
URL



What is the rate of hostname creation?
How many different end points?
How many different hostnames?

Account Creation

Username
Date time
IP Address
User Agent



Hostname Creation

Datetime
Hostname
IP Address
URL
User Agent

Was the account created from an IP in the same netblock as the IP the hostname is set to resolve to?

Does the GeoIP of address place them in the same country? Continent?

Example: Phishing

Hostname Created

u876trtr.fuettertdasnetz.de
uy85rr.is-a-candidate.org
3yi87.is-a-geek.org
awu7o.is-a-soxfan.org
hguy5434rer.is-with-theband.com
ui783ert.from-ok.com
d3678iyhgfd.space-to-rent.com
xey6hg.is-a-socialist.com
2hmmn7.from-wv.com
a54hgh.from-ky.com
yu74er.isa-geek.net
3gtij5.ham-radio-op.net

If we strip off the domain portion

u876trtr
uy85rr
3yi87
awu7o
hguy5434rer
ui783ert
d3678iyhgfd
xey6hg
2hmmn7
a54hgh
yu74er
3gtij5

Lets review the data

- User created a total of 12 domains
- User's account contains 12 domain names
- Names appear to be pseudo-randomly generated
- All created within 10 mins of purchasing the service
- All of the domains resolve to the same wordpress instance
 - Wordpress instance URI contains string "wp-content"
 - Wordpress instance URI contains pseudo-random generated html end point

Rate of name creation, number of persistent names, and the end points all point to phishing

Exploit Kits

Exploit kits are application infrastructure designed for compromising end user systems

- Keep track of where the end user came from
 - Source of traffic
 - Geography of end user
- Most have a number of different vulnerabilities they can leverage to accomplish their goal
 - Track what vulnerability was used to compromise the end users system
 - Track success rate
- Impressive focus on business metrics

Finding end user traffic to exploit is a different core competency than operating exploitation infrastructure
Traffic Direction Services serve three basic functions

- Steering traffic
 - By GeoIP, User Agent, Operating System, Referral
- Filtering traffic
 - Rules for dealing with security firms, search engine content review bots ... etc
 - Example: If IP belongs to GoogleBot redirect to clean page
- Collecting traffic metrics
 - Reporting on the two functions above for tracking / billing

Segmentation of Exploit Kits and Traffic Direction Services

- Allow groups / actors to focus on their core competency
- Traffic direction services help protect exploit kits / mitigate the risk of losing the exploit node
- Exploit kits are centered around maximizing the infection rate of traffic which they receive

Activity Fingerprint

- mlviwwiokblfqj.dnsdojo.com
- mocqrrrnqxeujejthn.dnsdojo.com
- hdpbdwndymbtrsvxship.dnsdojo.net
- youbljtwmqfpggrest.dnsdojo.net
- pxwkcdewyrqu.dnsdojo.net
- kmevvtioxwu.dnsdojo.net
- ilustyewwwiec.selfip.biz
- pporvwwsrqfwqdiiqvj.selfip.biz
- ifwutmgylrno.selfip.biz
- hxlswcwsyodq.selfip.biz
- mqydnjycdjmpdqhs.selfip.biz
- wqkcrphwlxv.selfip.biz
- fwklleuqdogcmhxtirw.selfip.biz
- 45400f3233e52d15694cf990.worse-than.tv
- 26745522c585519482f0e3e3.worse-than.tv
- d22a34203ed4dc4571e361de.worse-than.tv

Accounts contain 3 to 5 hostnames active at a time

Domains are pseudo-randomly generated

They rotate on a fixed interval 5 min / 30 min / 1 hour

The endpoint is usually the same IP address for a day or more

Rate of name creation, number of persistent names, and end points = TDS / Exploit Kit

Scenario Difference

- Phishers need the domain used in their campaign email to stay active
- Exploit / TDS campaigns rotate these domains frequently to avoid detection
 - Key Variables: **Total number of domains active at one time & Persistence**
- Phishers have been using compromised CMS instances to host their pages
- Exploit / TDS campaigns, ones that use our DDNS, are all using cloud / VPS providers
 - Key Variable: **End point classification**

IP Reputation Profiling

- Does an account have multiple domains or IPs from known questionable ASes?

Does an account have a collection of domains with similar query volume?

- How long has the host existed?
- How many new hosts have been created or deleted?
 - For those defending networks this is a case where looking at passive DNS would help

- Identify customers with the high rates of domain creation
 - Is it accompanied by a high rate of removal
- Quantify the diversity of IPs creating records with the A record IP
 - This helps clarify if the account is being shared
- Quantify the diversity of IPs being used for A record IPs
- AS Profiling of IPs
 - Infrastructure as a service provider
 - Small / Midsized ISP
 - VPN provider / Tor Exit Nodes



中国互联网安全大会



360互联网安全中心

Number of Queries Per Domain Per Campaign

Number of Queries per Domain Used

7500

5000

2500

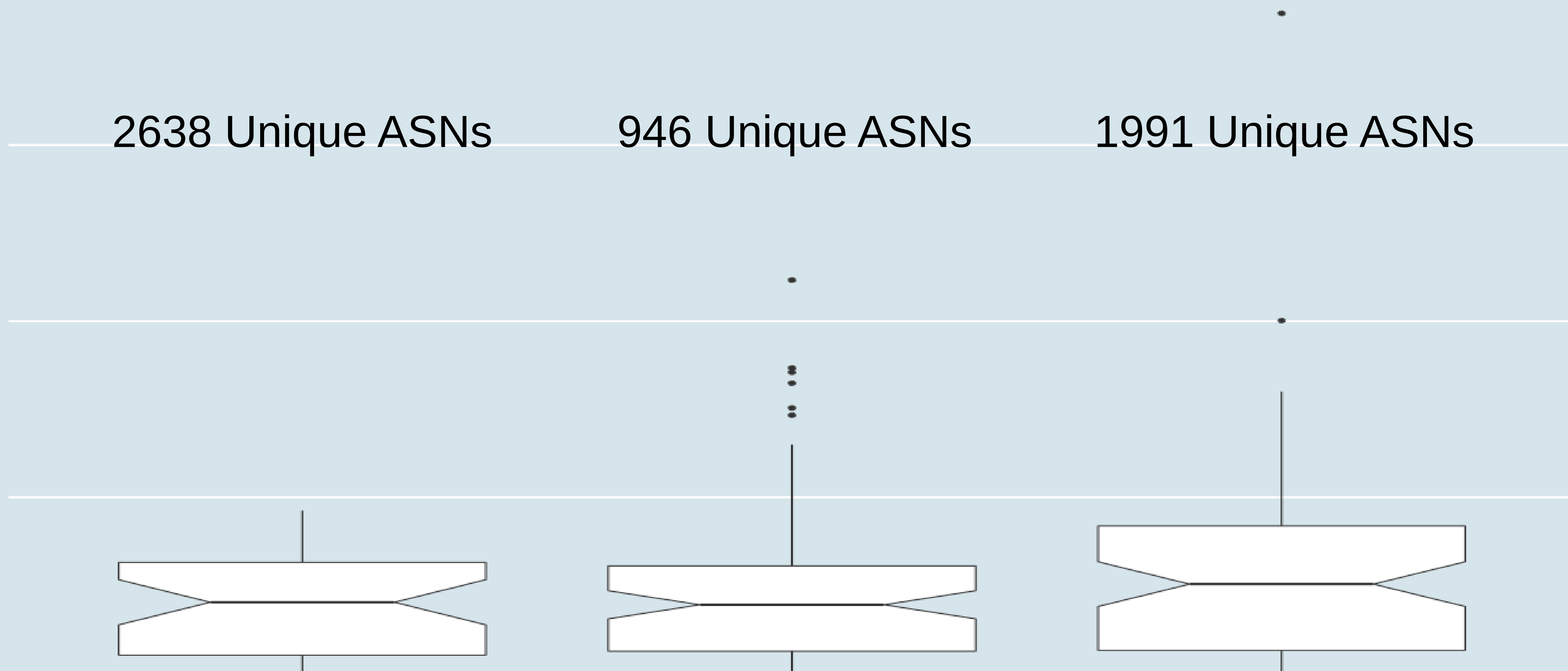
0

2638 Unique ASNs

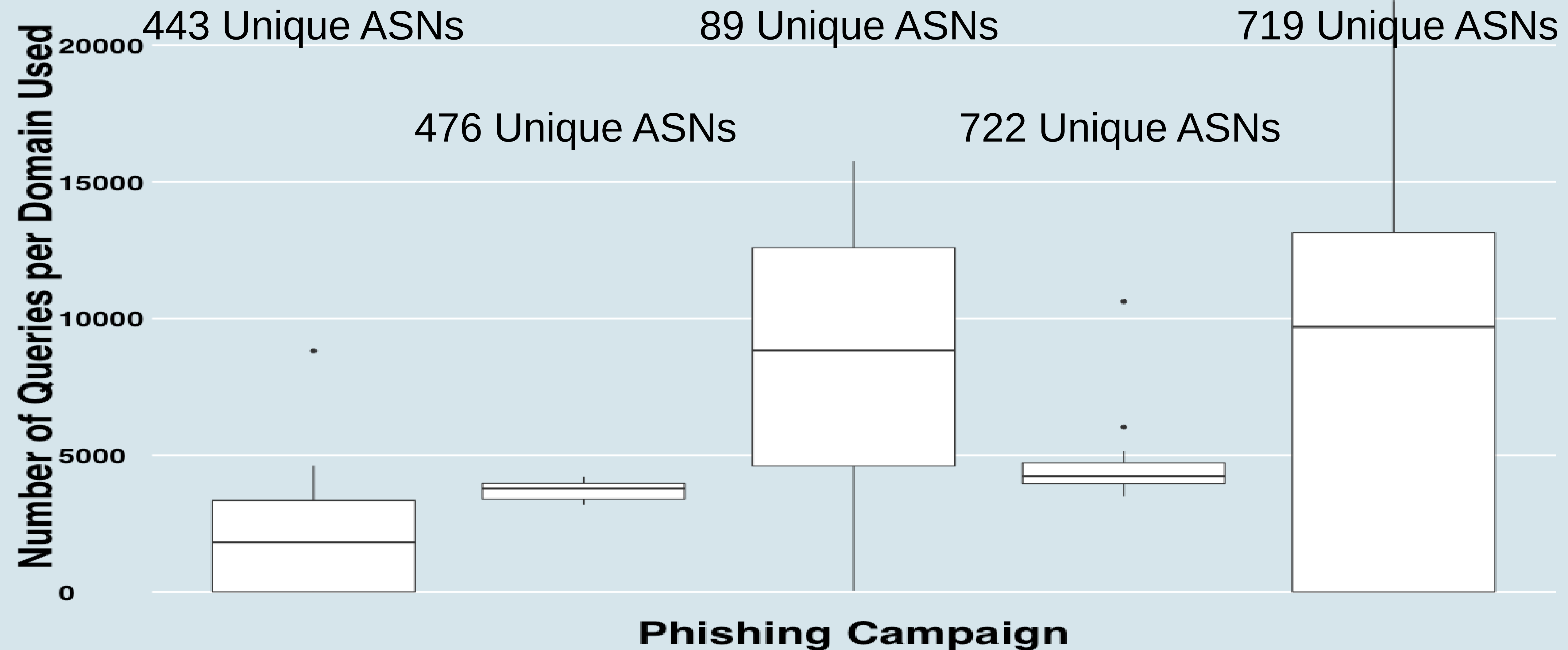
946 Unique ASNs

1991 Unique ASNs

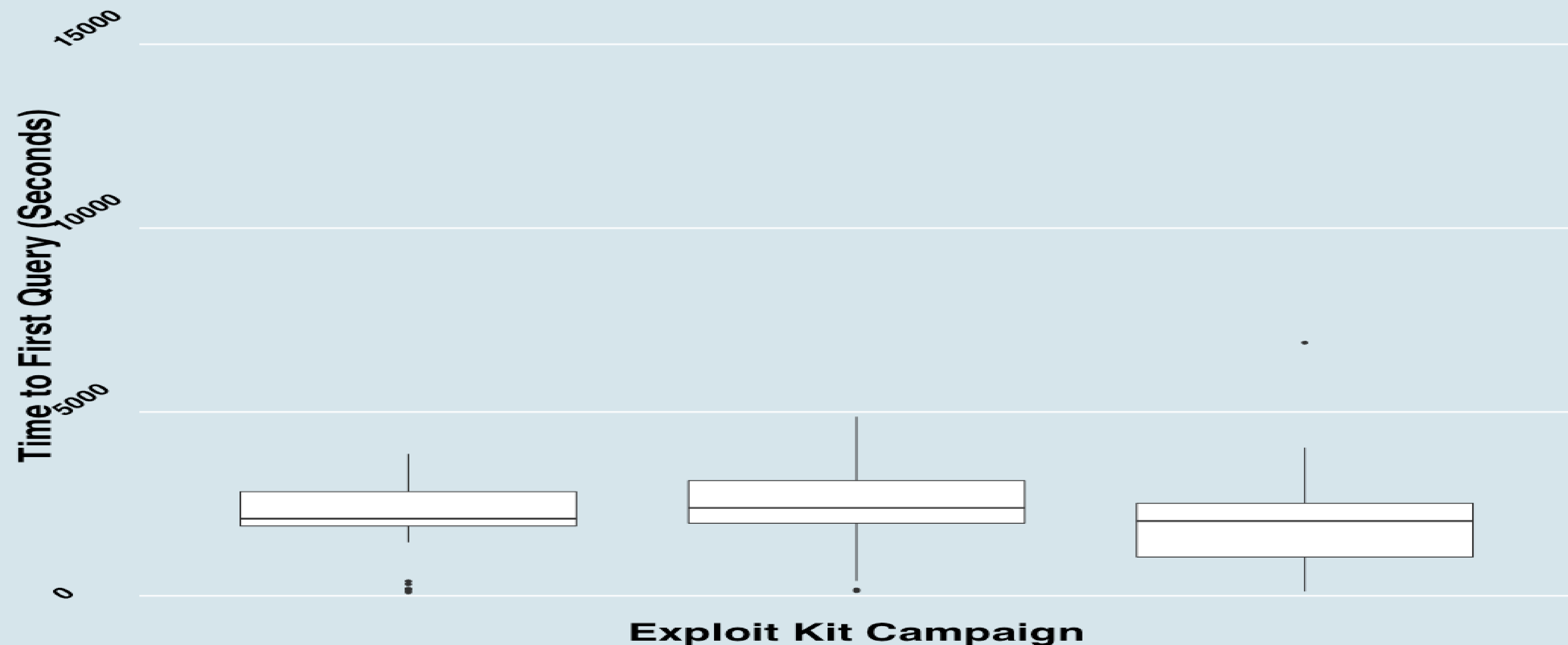
Exploit Kit Campaign



Number of Queries Per Domain Per Campaign

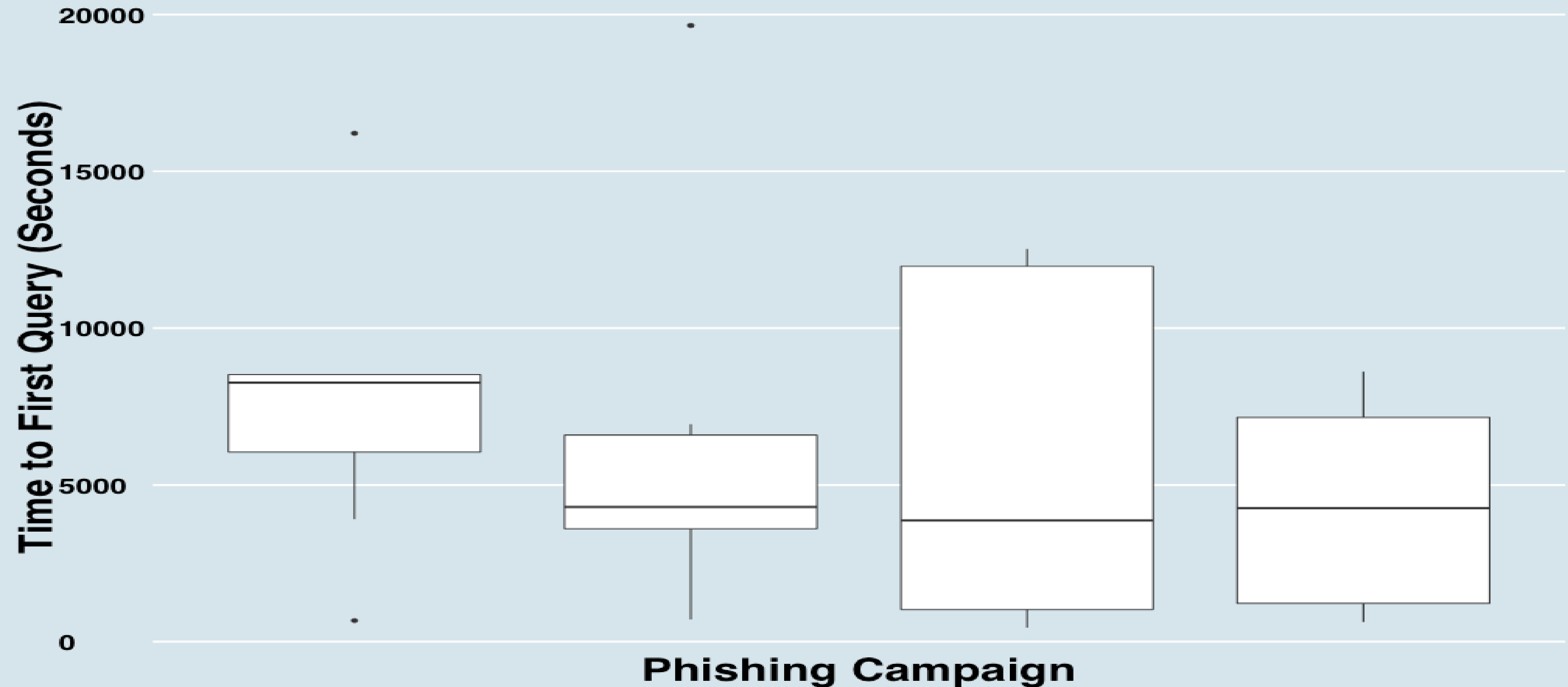


Time to First Security Company Query





Time to First Security Company Query



We can close the account stopping their ability to create more domains

Report the credentials they used to pay for the account

But first it is key to point the domains to a sinkhole

- If we just close and block them we have no insight into the volume of traffic and the type of traffic associated with the domain
- Sinking domains in the case of TDS / Exploit kits provides insight into the referrers and or criminal infrastructure
- Sinking domains in the case of phishing exposes additional URIs of interest

Adapting Identification Methodology

1: Jscript Infection

2: DNS Beacon Malware

Case 1: JS Backdoor

There is a compromised machine with a backdoor on a single host. Vendor detection is non-existent. It is a JS backdoor making C2 connections at regular intervals.

C2 connections are made to the below:

62.76.184.160, *.endofinternet.net

GET

https[:]//offpotubeda.endofinternet[.]net:443/related/?action=get_conf
ig

&guid=<redacted>&version=1115

Quantify

- 22 accounts at the time had hostnames related to 62.76.184.160

Identify

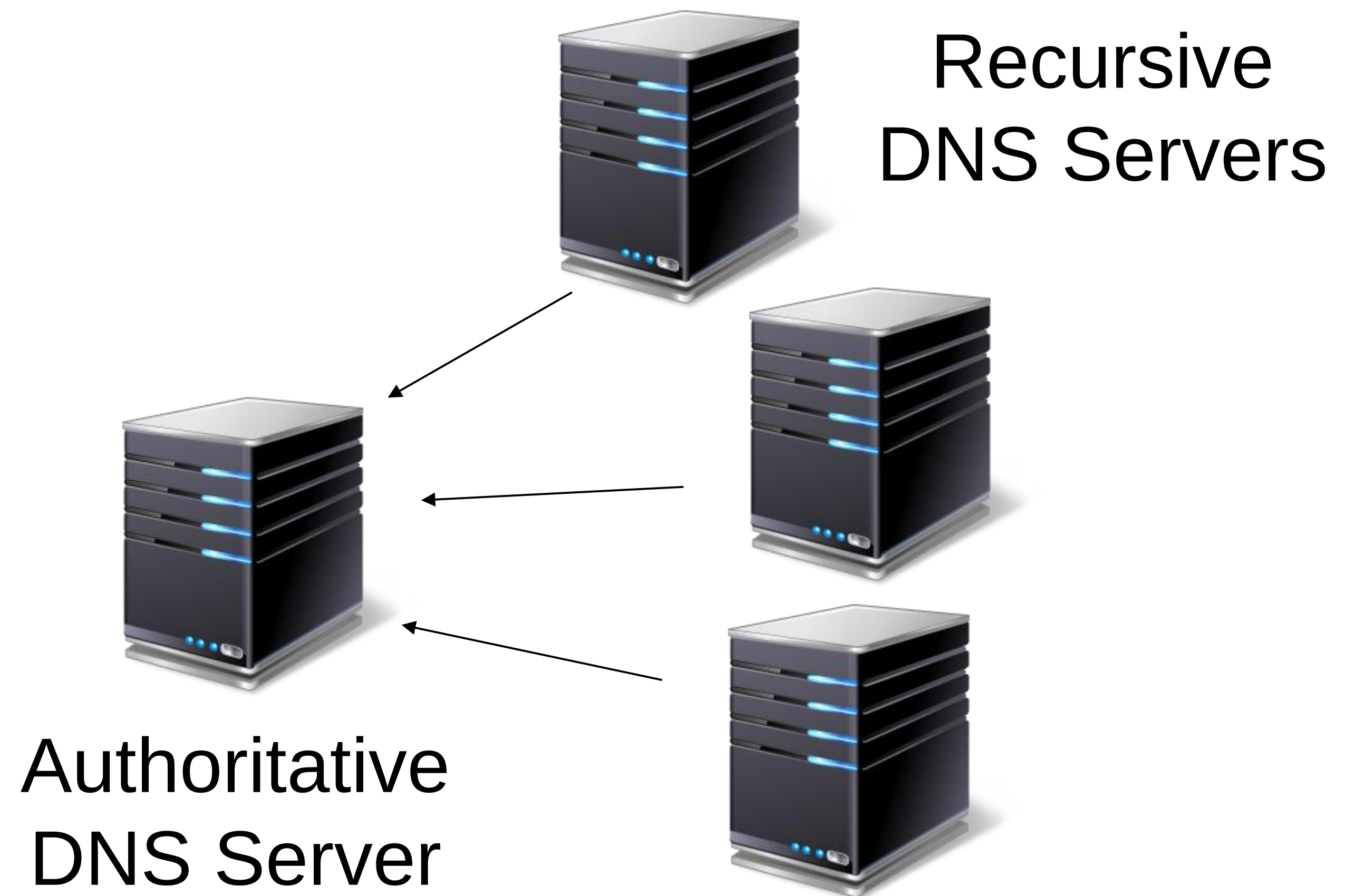
- The account associated with the supplied malicious hostname created it from 85.214.23.62

The impacted party provided a copy of the .js file they found on the infected machine

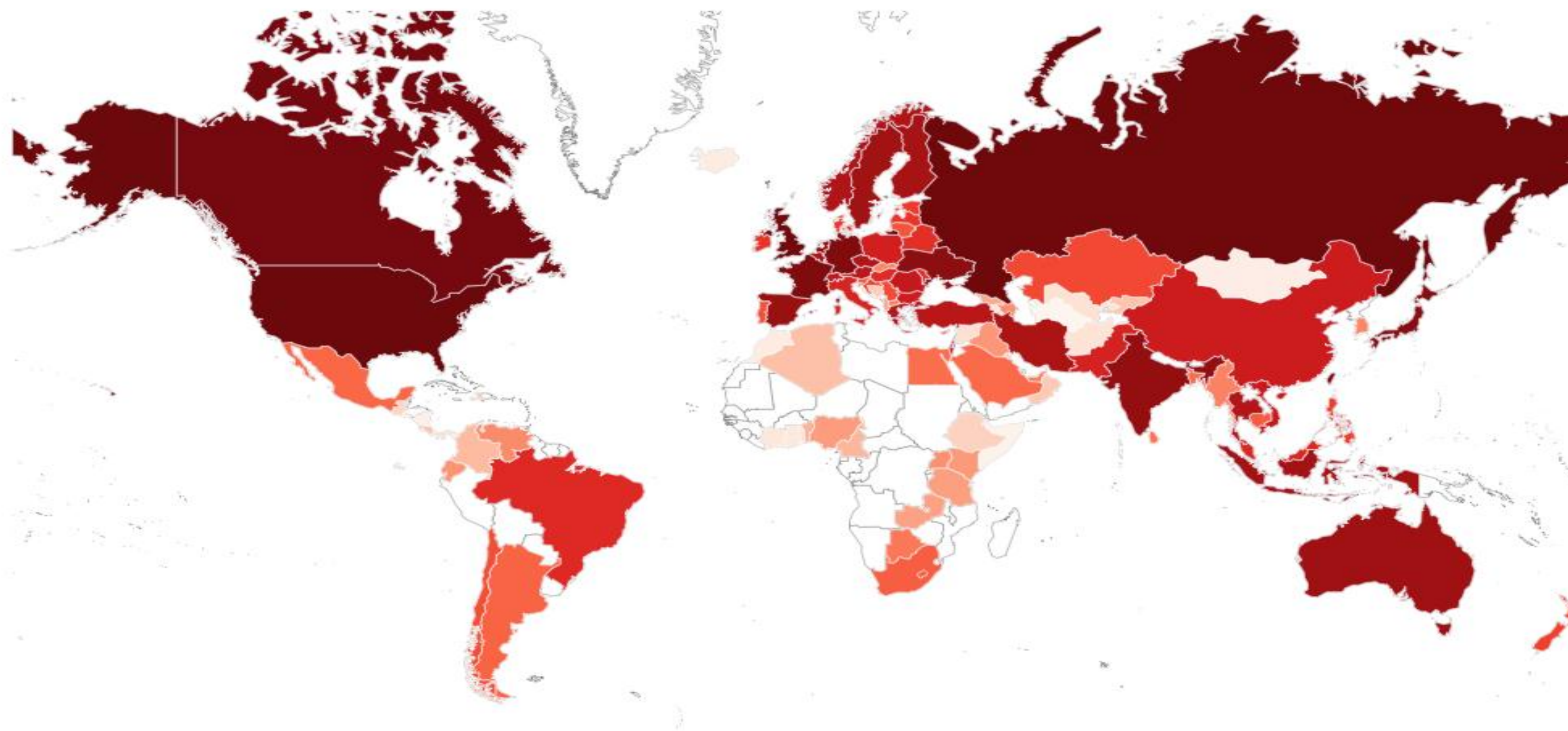
Between the email and account usage history, it seems clear a domain generation algorithm was being used

Who asked for what?
When did they ask for it?
How often are they asking?

```
Epoch> 203.0.113.1#8899  
offpotubeda.endofinternet.net  
<Epoch> 203.0.113.2#8899  
offpotubeda.endofinternet.net  
<Epoch> 203.0.113.3#8899  
offpotubeda.endofinternet.net  
<Epoch> 203.0.113.4#8899  
offpotubeda.endofinternet.net
```



Endpoints Requesting DGA Domains



Country						
TM	ET	NG	AR	BR	BE	
SV	BM	KE	CY	MY	FI	
SO	BA	IQ	ZA	IT	ID	
SC	OM	EC	KH	PK	SE	
NI	KW	UG	SI	PL	AU	
MN	KG	AZ	LT	BG	ES	
MA	HT	VE	PT	SG	IN	
IS	DZ	KR	CL	CN	NL	
GH	CR	SK	RS	VN	UA	
DJ	CO	MM	KZ	IL	JP	
CI	CM	MK	HR	RO	DE	
AM	BN	AE	NZ	EU	FR	
AF	BJ	MT	PH	CH	TW	
UZ	MV	BW	EE	AT	CA	
TG	HK	LU	DK	TR	GB	
SY	GE	LK	LV	GR	RU	
PA	BH	EG	IE	TH	US	
MC	AL	BD	MD	CZ		
GT	ZM	SA	BY	NO		
FJ	TZ	MX	HU	IR		

In most cases the requestor for authoritative DNS records is a recursive resolver

This is one way to assess potentially impacted organizations or geographies

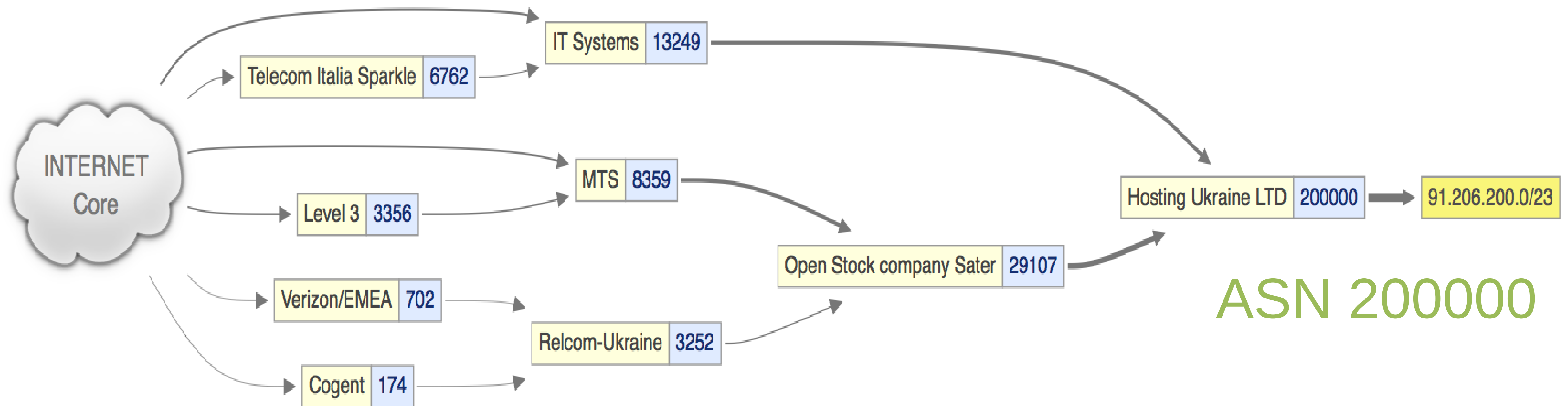
A majority of recursive resolvers on the internet implement DNS source port randomization

- <https://tools.ietf.org/html/rfc5452>

91.206.201.240 and 2001:67c:2070:8b06::2 where only requesting DGA domains and always using source port 53 (for IPv4)

DGA domains and always using source port 53 (for IPv4)

- "Delta-X" LTD Ukriane, Kyiv.



Unlike all of the other requests 91.206.201.240 was also appending a hash to each authoritative request while requesting the base domain in the same second

- 1431410081 a3f34ef153f6b09091ad104add8e5e987.isctm.isteingeek.de
- 1431410081 isctm.isteingeek.de
- 1431410081 a52b42798f141810d0a1afe6866d25945.offtumtube.endofinternet.net
- 1431410081 offtumtube.endofinternet.net
- 1431410081 a21f37dc477d63b21a63aad450f580742.netpotubeda.servebbs.com
- 1431410081 netpotubeda.servebbs.com
- 1431410081 a2bf47eb9d1297cc614fcc876af7ac28e.webgdame.isteingeek.de
- 1431410081 webgdame.isteingeek.de

While digging into this portion Daniel Plohmann was able to reverse engineer the DGA

The hosts the DGA was targeting:

- servebbs.com
- isteingeek.de
- endofinternet.net

As well as the collection of ngrams which are used to generate the third tier domain name:

o h us what si as is off net web call how ask e l code q c tu po g t m tube da me r no ko s i le d si
te na f p k un b on ri make in n a host ad old for j own to

With the DGA solved it became feasible to register the domain names before the actor

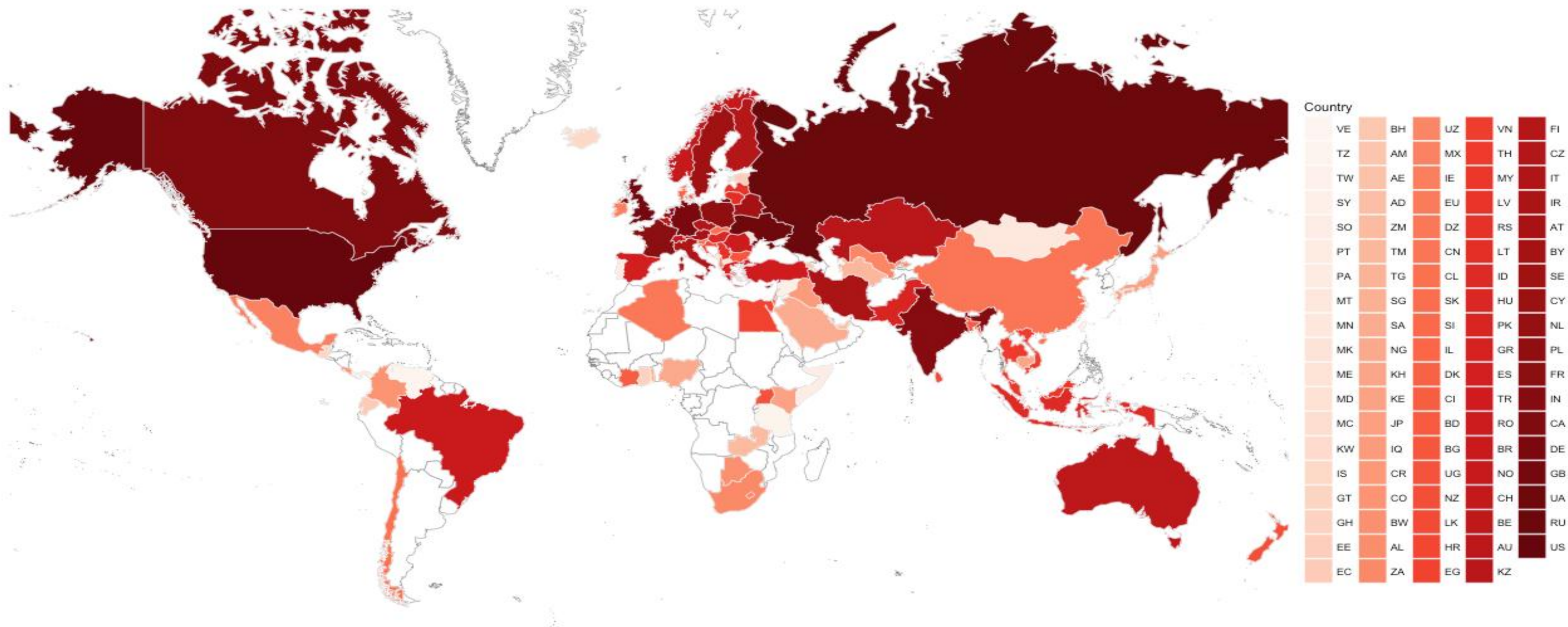
- Instead of reclaiming the domains after they were registered

Preregistration began ...

- IPs from 1,358 ASNs made connections to the sinkhole
- ASNs with ties to 117 countries
- 14,185 unique IPs made connections to the sinkhole during the first 5 days of observation

Due to the number of infected end points and their profile we generated a feed for ShadowServer

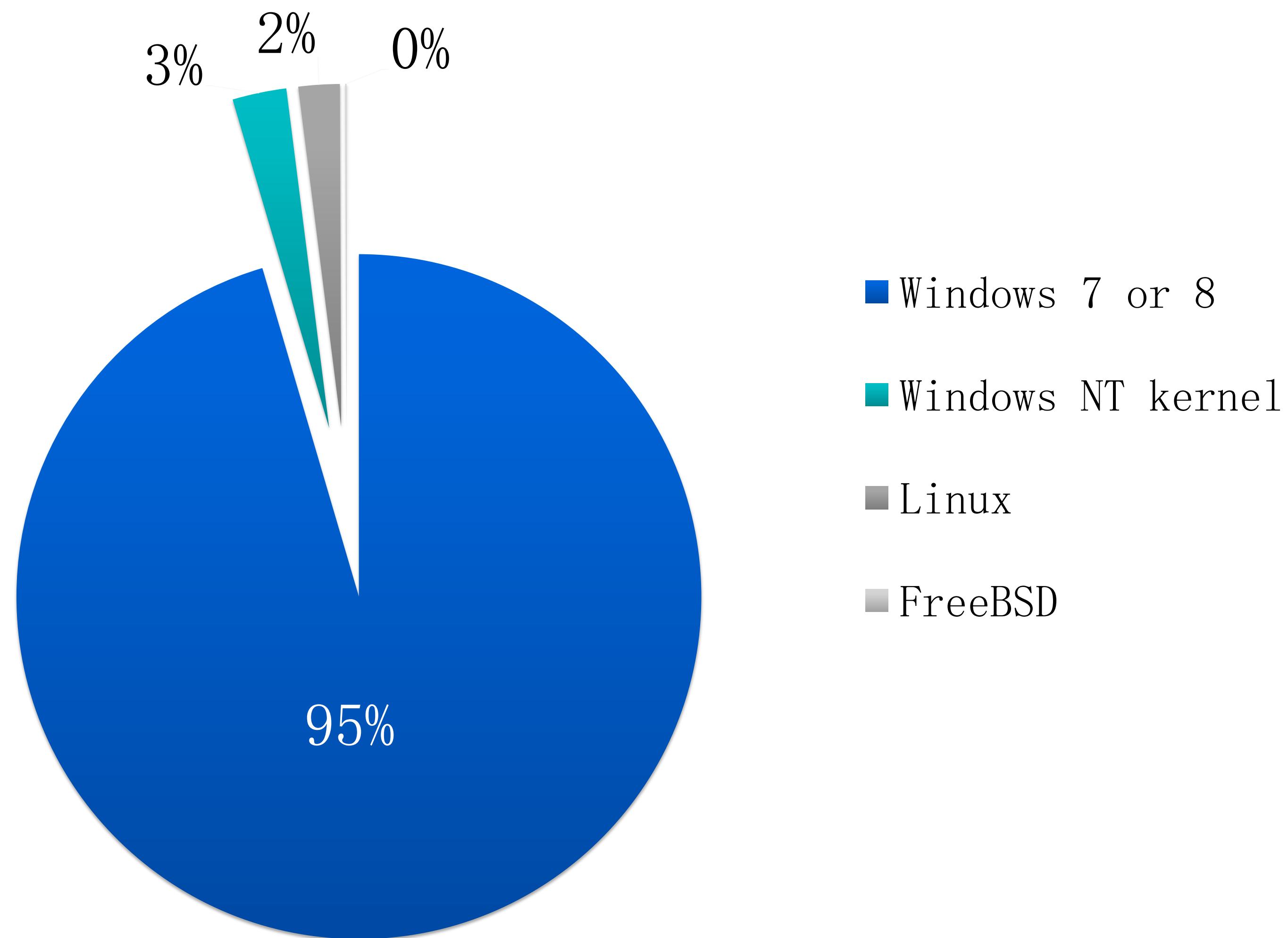
Windows Endpoints to Sinkhole



Despite looking like Javascript, the malware was written in "Jscript"

- A Javascript like vbscript alternative created by Microsoft
- This nuance hinted that it might be a good idea to ensure that we p0f or another OS fingerprinting tool was deployed to the sinkhole
- The goal of this being the ability to segment "possibly infected" from "research related" requestors operating under the theory that only things with Windows fingerprints should be considered

Verifying p0f fingerprints



Why didn't your Exploit Kit / Traffic Direction Service pattern pick this up?

- Its registering domains on a fixed interval
- Its adding and deleting domains to accounts that resolve to the same endpoint

They split the activity up across multiple accounts ...

- One account would add a domain
- Another account would add the follow up domain ... etc

One important take away from this was to take a wider view and look at finding activity splayed across end points

Also looking at recursive traffic for the domain is key

They used a set of ngrams which make
“less anomalous looking” names

Some of the domains are even all real
words!

Earlier we were looking at domains like:
`mqydnjycdjmpdqhs.selfip.biz`

- Long runs of only consonants
- A lack of common vowel consonant groupings ...

- `owhatnetweb.isteingeek.de`
- `hsiwebcall.endofinternet.net`
- `usascallhow.servebbs.com`
- `whatishowask.isteingeek.de`
- `asnetel.servebbs.com`
- `iswebocode.isteingeek.de`
- `offcallcodeq.endofinternet.net`
- `nethowqc.servebbs.com`
- `webaskctu.isteingeek.de`
- `calletupo.endofinternet.net`

In early December 2014 we received a sample from ShadowServer unlike others seen in the past

- It was of specific interest because the sandbox showed some very interesting DNS traffic

On Jan 11th 2015 infosecotter.com posted a detailed look at the North Korean Central News Agency webserver

The post had details about a specific type of malware being distributed from the website

The domain, a.gwas.perl.sh , is requested by the malware

The resulting IP address of the DNS query of a.gwas.perl.sh (211.233.75.83) is then sent a DNS query

The target domain is a string which presumably identifies features about the infected victim.

No.	Time	Source	Destination	Protocol	Length	Info
22	19.407682	192.168.56.101	211.233.75.83	DNS	87	Standard query 0x7c5e CNAME CSpqaSwGBwYGxicHSWmmacg.g.r
23	20.405315	192.168.56.101	211.233.75.83	DNS	87	Standard query 0x7c5e CNAME CSpqaSwGBwYGxicHSWmmacg.g.r
24	21.407181	192.168.56.101	211.233.75.83	DNS	87	Standard query 0x7c5e CNAME CSpqaSwGBwYGxicHSWmmacg.g.r
25	23.410002	192.168.56.101	211.233.75.83	DNS	87	Standard query 0x7c5e CNAME CSpqaSwGBwYGxicHSWmmacg.g.r
26	27.415278	192.168.56.101	211.233.75.83	DNS	87	Standard query 0x7c5e CNAME CSpqaSwGBwYGxicHSWmmacg.g.r

As this was making its way to the blog-o-sphere a rag tag band was looking into a similar sample

- Daniel Plohmann of Fraunhofer FKIE
- Steven Adair of Volexity

The initial relationship was centered on the domain `a.gwas.perl.sh`

Then after seeing what Cylance published about the domain names used for beaconing we could confirm that the network communication looked the same

The binary our team was focusing on used 3 hard coded C&C nodes:

- a.gwas.perl.sh
- a-gwas-01.slyip.net
- a-gwas-01.dyndns.org

The latter of the domains is one which is using Dyn' s Dynamic DNS platform

After going over the incident with our Customer Service team the domain was move to a sinkhole

Who is asking?

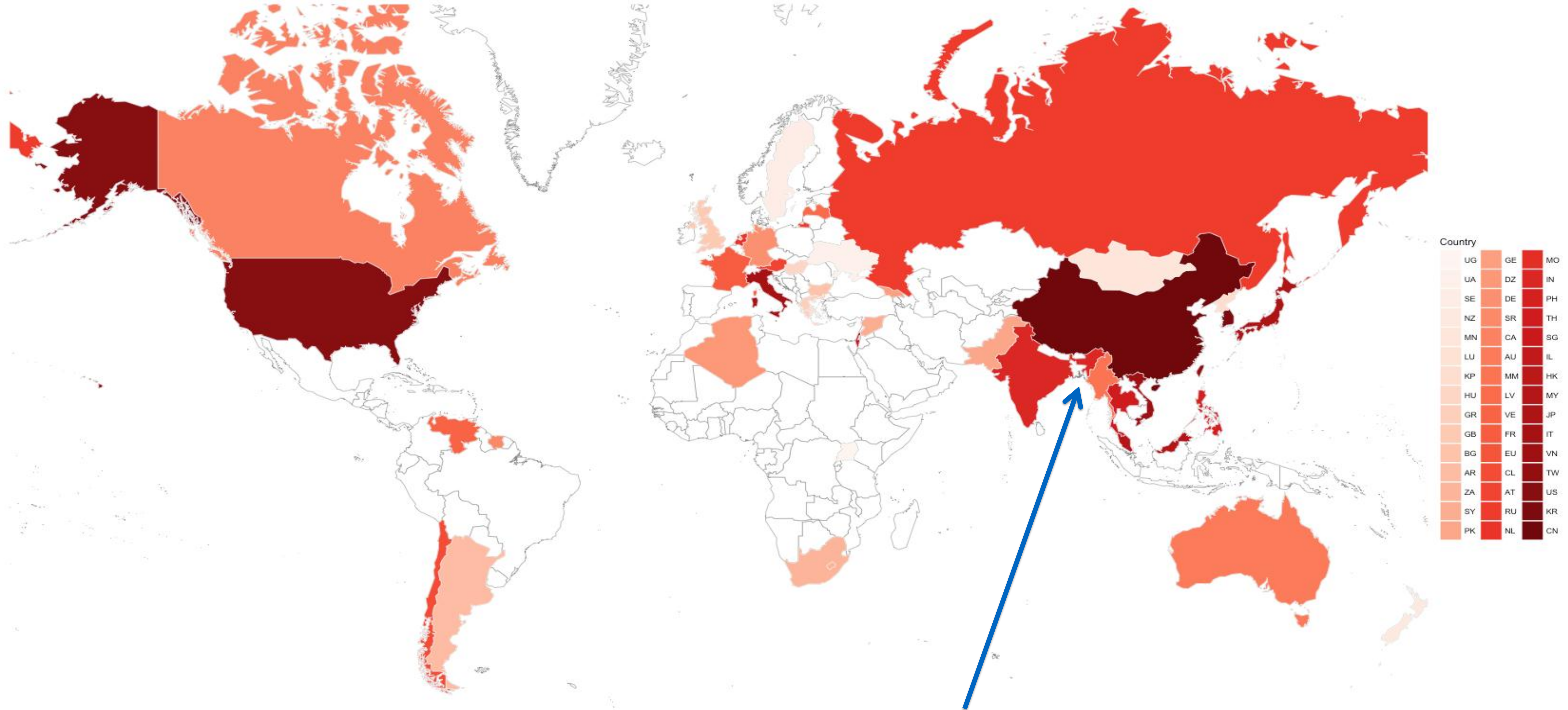
With the domain resolving to a sinkhole we now were receiving all of the traffic originally destined for the C&C domain

This allowed us to capture the DNS beacon queries

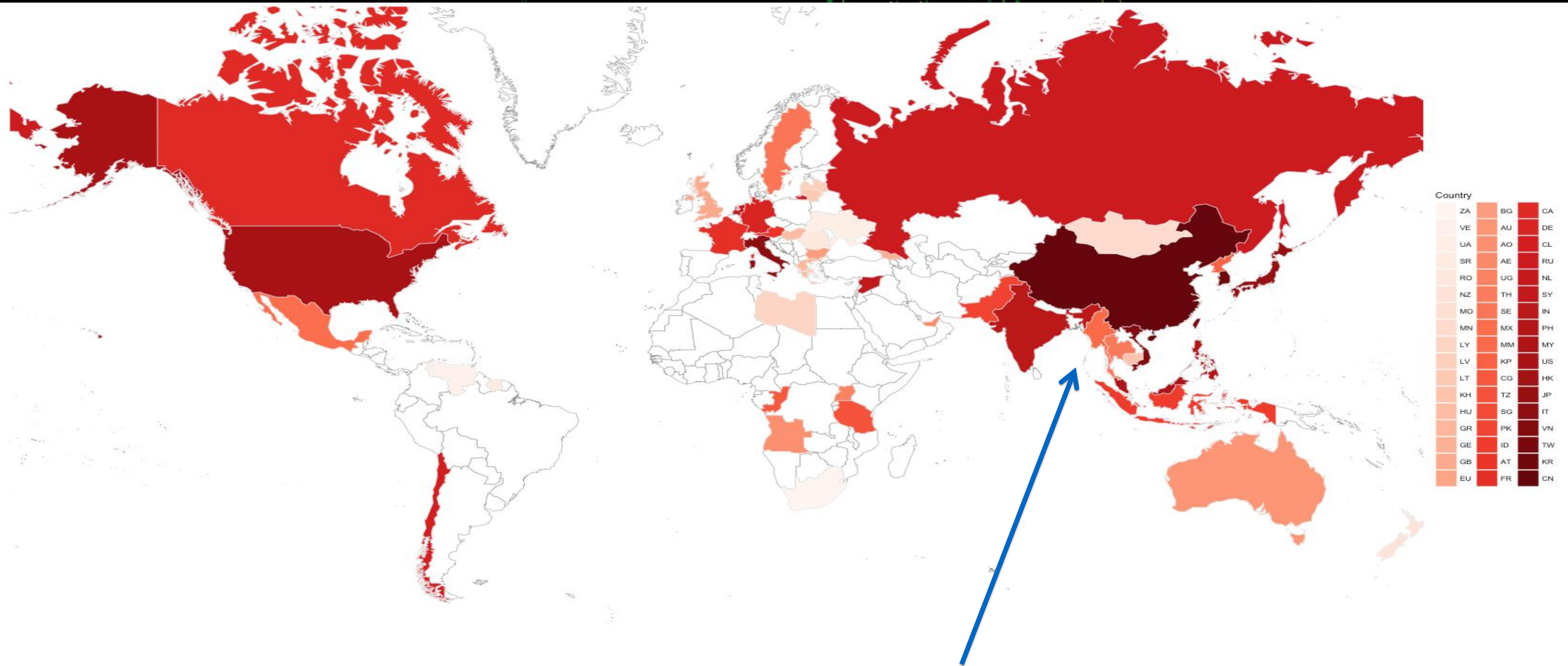
At first we were using BroIDS to log all of the DNS traffic, however it was running a lower case function on the CNAME

This lead to a switch to the most rich data stream full network capture!

aka tcpdump



The scale helps show the diversity but $> 99\%$ of the queries are from CN



The scale helps show the diversity but > 99% of the beacons come

Daniel reverse engineered the CNAME into the details it was seeking to communicate

- Example: qAnpSuhmxoZhhugHpqYnLAYHBgbGJ-dH60bIpg. g. r
- Computername_MAC address (hex-representation)

Computer names may show up with multiple MAC addresses (e.g. Ethernet and WiFi)

Different machines can have the same computer name

This leads us to assume the infection population is between 44,000 and 65,000 unique machines.

Signals in CNAMEs

CNAME Top Level Domain	Alpha Numeric Transform	Windows Version
. g. r	5. 1	Windows XP
. g. s	6. 1	Windows 7
. h. r	6. 2	Windows 8

Examples	Version Flag
qAnpSuhmxoZHhugHpqYnLAYHBgbGJ-dH60bIpg. g. r	. g. r
imsn5yfm54YsBgZnBmdHZwZp56iG. h. r	. h. r
yapmCqgsaQfn6AdJiKbIq0eo. g. s	. g. s
CiqqxiwnhoiGpmdp50cGBgc. h. s	. h. s
aaZmBicsJ4aIhqZnyMZn50mI. f. s	. f. s

78,748 – Unique Source IP Beacon pairs

52,653 – Unique IPs

40,165 – Unique Beacon CNAMEs

The infection footprint of this malware continues to persist. Based on earlier caveats we estimate the infected population to be between 35,000 and 45,000 endpoints

Dynamic DNS is frequently abused by criminals and larger scale actors

- Patterns can be observed which help categorize the activity
 - Rate of domain creation
 - Duration of domains existence
 - Number of queries per second to the domain
 - Number of end points querying the domain

If you come across any cases where Dyn's Dynamic DNS is being abused please don't hesitate to contact me.

Thank You!



中国互联网安全大会



360互联网安全中心